

Data Privacy and Compliance Report

Name: Solomon Mwaura

Date: February 20, 2026

Role: Junior Security Analyst

Applicable Regulations and Standards

The regulatory framework governing this assessment is primarily the **General Data Protection Regulation (GDPR)**, with a focus on **Article 32 (Security of Processing)** and **Article 5 (Principles of Processing)**. Additionally, the **CIS (Center for Internet Security) Benchmarks** for Linux provide the technical baseline for these requirements.

- **Key Compliance Requirements:** GDPR requires technical measures to ensure the **Confidentiality, Integrity, and Availability** of personal data. Specifically, access controls must follow the "Principle of Least Privilege," ensuring that users only have access to the data necessary for their roles. For home directories, this means strict ownership and restricted permissions (e.g., 750 or more restrictive).
- **Criticality:** Meeting these requirements is critical to prevent unauthorized data access and "lateral movement" within a system. If permissions are misconfigured, a breach of a single non-privileged account could lead to a system-wide exposure of sensitive personal information, resulting in significant legal and financial penalties for the organization.

Compliance Assessment Findings

The Lynis audit identified several critical vulnerabilities and configuration gaps that directly conflict with the established standards:

Vulnerability Flagged	Compliance Standard (CIS)	Risk Description

Incorrect Home Dir Ownership (HOME-9306)	CIS Benchmark 6.2.8	Unauthorized Access: User "Smalls" owned "Benny's" directory, and "Benny" owned "AnotherUser's" directory. This allows users to read, modify, or delete each other's personal data.
World-Readable Cron Files (FILE-7524)	CIS Benchmark 5.1.2	Information Leakage: System-wide schedules were visible to all users, exposing administrative paths and script locations that can be exploited for privilege escalation.
Lack of Unique Host ID (GetHostID)	GDPR Art. 5.2 (Accountability)	Traceability Gap: The system failed to generate a unique HostID, making it difficult to verify which specific node was involved in a security event during forensic analysis.
Missing Systemd/Journal Tools (PLGN-3814)	CIS Section 4 (Auditing)	Detection Gap: The absence of integrity checking for system journals means an attacker could modify logs to hide their activity without detection.

Remediations Implemented

To mitigate the identified risks and bring the system into compliance, the following technical actions were taken:

- **Ownership Re-alignment:** Executed recursive ownership changes:
 - `chown -R Benny:Benny /home/Benny`
 - `chown -R AnotherUser:AnotherUser /home/AnotherUser`
 - **Purpose:** This isolates user data at the kernel level, ensuring only the intended user (or root) can access personal files.
- **File Permission Hardening:** Updated the system crontab:
 - `chmod 600 /etc/crontab`

- **Purpose:** Restricts system scheduling metadata to the root administrator, preventing low-privileged users from discovering administrative windows of opportunity.
 - **Access Control Standardization:** Enforced permissions of 750 across all home directories.
 - **Purpose:** This prevents "World" access entirely, supporting GDPR's mandate for "Privacy by Default."
-

Compliance Alignment and Broader Impact

These remediations directly addressed GDPR requirements by enforcing **Data Isolation** and **Integrity**.

- **Restricting Permissions:** By locking down sensitive files like `crontab` and correcting home directory ownership, we ensured that personal data is protected from unauthorized viewing (**Confidentiality**) and unauthorized alteration (**Integrity**).
 - **Organizational Impact:** These actions significantly improve the organization's security posture by reducing the "attack surface." In a multi-user environment, ensuring that users cannot peek into each other's directories is a fundamental step toward building a trust-based data environment and meeting the standard of "Security of Processing" required for handling sensitive stakeholder information.
-

Compliance Reflection and Recommendations

Reflection on Compliance Efforts

The assessment, remediation, and safeguards implemented in this report align with the **Accountability** principle of GDPR. By performing the Lynis audit, we moved from an assumed state of security to a verified one. The technical fixes directly support the legal requirement to protect user data from internal and external threats, effectively raising the system's Hardening Index and resilience.

Lessons Learned

- **Technical/Legal Alignment:** I learned that a minor technical oversight (like a `chown` error) is a major legal liability under GDPR. Every permission bit has a direct impact on regulatory compliance.
- **The Importance of Auditing:** This experience reinforced that continuous monitoring is mandatory. Without regular audits, "configuration drift" can quietly re-introduce vulnerabilities that were previously patched.

Recommendations for Maintaining Compliance

1. **Regular Auditing:** Implement weekly automated Lynis scans via cron to identify new vulnerabilities or permission changes immediately.
2. **Employee Training:** Conduct quarterly workshops for all users (e.g., Benny, Smalls, Squints) on secure data handling and the importance of maintaining restricted directory permissions.
3. **Address Logging Gaps:** To resolve the "unresolved" journal integrity and HostID issues, I recommend migrating the environment to a full OS image that supports **systemd** or implementing a centralized, off-site logging server (ELK stack) to ensure audit trails are immutable and searchable.
4. **Policy Updates:** Review access control policies bi-annually to adapt to evolving GDPR interpretations and emerging cybersecurity threats.